Incident Report – MySQL Ransomware Attack and Data-Destruction on dataorg-dv-28m

Incident: MySQL Ransomware Attack and Data-Destruction

Asset Identified: `dataorg-dv-28m` (Azure Virtual Machine)

Date of Report: October 22, 2026

1. Executive Summary

Between October 9 and October 13, 2026, the internet-facing Azure virtual machine `dataorg-dv-28m` suffered a severe, multi-staged breach executed by disparate automated threat actors. The incident began with the exploitation of an exposed MySQL service via a misconfigured root account, which facilitated the unauthorized exfiltration of sensitive Personally Identifiable Information (PII).

Following data theft, the adversary executed a destructive ransomware payload, systematically dropping all operational databases and leaving an extortion demand. Subsequently, secondary threat actors capitalized on the host's exposed Remote Desktop Protocol (RDP) port, successfully brute-forcing the local Windows administrator account to establish interactive graphical sessions, resulting in total host compromise.

2. Incident Details

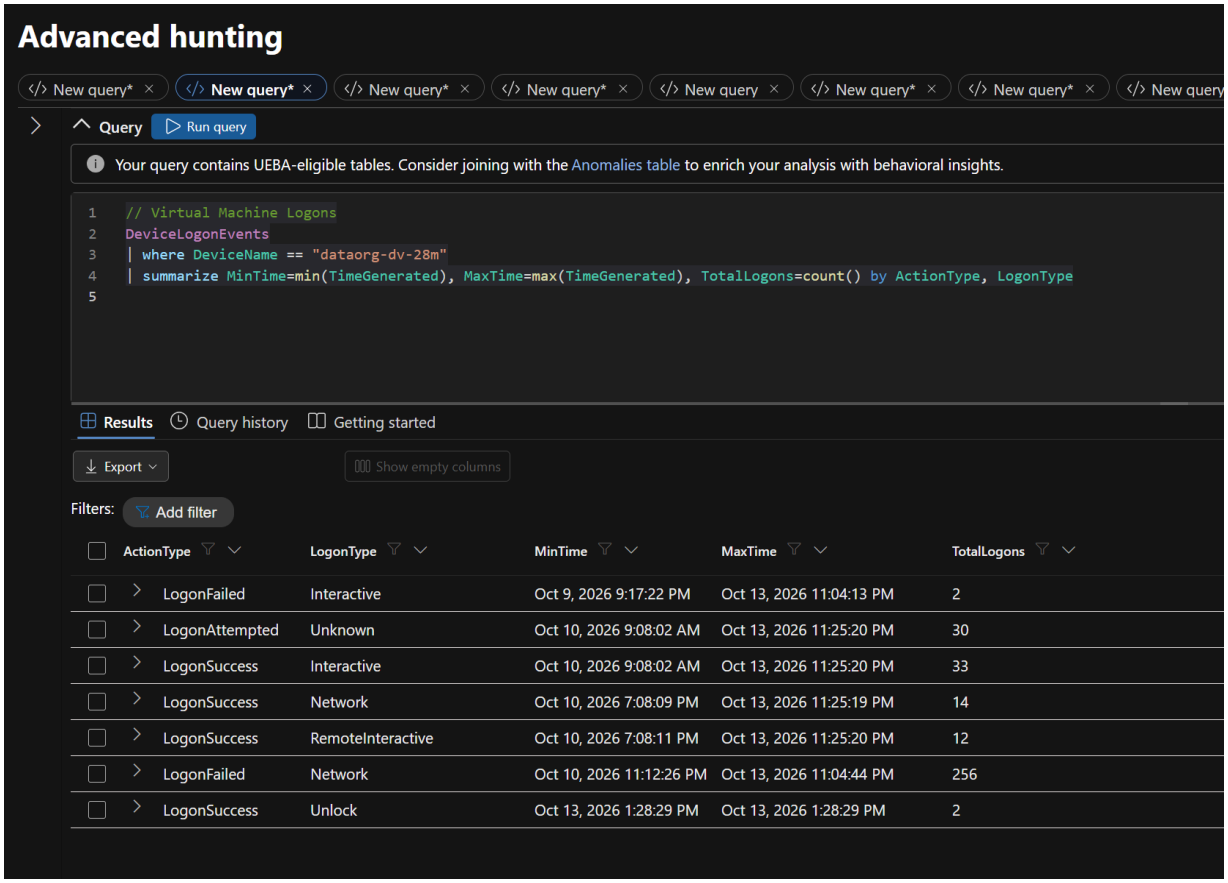
- **Incident ID:** IR-202610-001
- **Detection Date/Time:** October 10, 2026 (Initial Database Breach) / October 13, 2026 (Host OS Compromise)
- **Incident Commander / Reporter:** Automated Log Analytics / SOC Threat Hunting Team
- **Classification:** Unauthorized Access, Data Exfiltration, Data Destruction, and Ransomware
- **Severity:** Critical (Tier 1)
- **Affected Systems/Assets:**
    1. **Host:** `dataorg-dv-28m` (Azure Virtual Machine / Windows 11)
    2. **Service:** MySQL Database Instance (Port 3306)
    3. **Data Assets:** `dvm_corp` (Corporate Data), `sakila`, and `world` databases.

Hunting Query: Initial Scope

Code snippet

```
DeviceLogonEvents
```

| where DeviceName == "dataorg-dv-28m"
| summarize MinTime=min(TimeGenerated), MaxTime=max(TimeGenerated), TotalLogons=count() by ActionType, LogonType



3. Impact Assessment

- **Confidentiality (High Impact):** Verified data exfiltration occurred. Telemetry confirms a `SELECT` statement successfully retrieved customer records from `dvm_corp.customers`—including fields such as `customer_id`, `first_name`, `last_name`, `email`, `phone`, `street`, `city`, `state`, `zip`, `date_of_birth`, and `ssn`—exposing the organization to severe regulatory and legal liabilities.
- **Integrity (Total Loss):** The adversary bypassed relational database safeguards by systematically altering tables to drop foreign key constraints. All tables within the primary databases were subsequently destroyed via `DROP TABLE` commands, permanently altering the data structure.
- **Availability (Total Loss):** Following the structural destruction, the `dvm_corp`, `sakila`, and `world` databases were entirely deleted via `DROP DATABASE` commands. A new schema named `RECOVER_YOUR_DATA` was instantiated solely to house the threat actor's extortion demands.

- **Business Impact:** Complete loss of service for the affected node, significant reputational damage, and an immediate requirement for mandatory breach notification procedures due to the confirmed extraction of social security numbers and dates of birth.

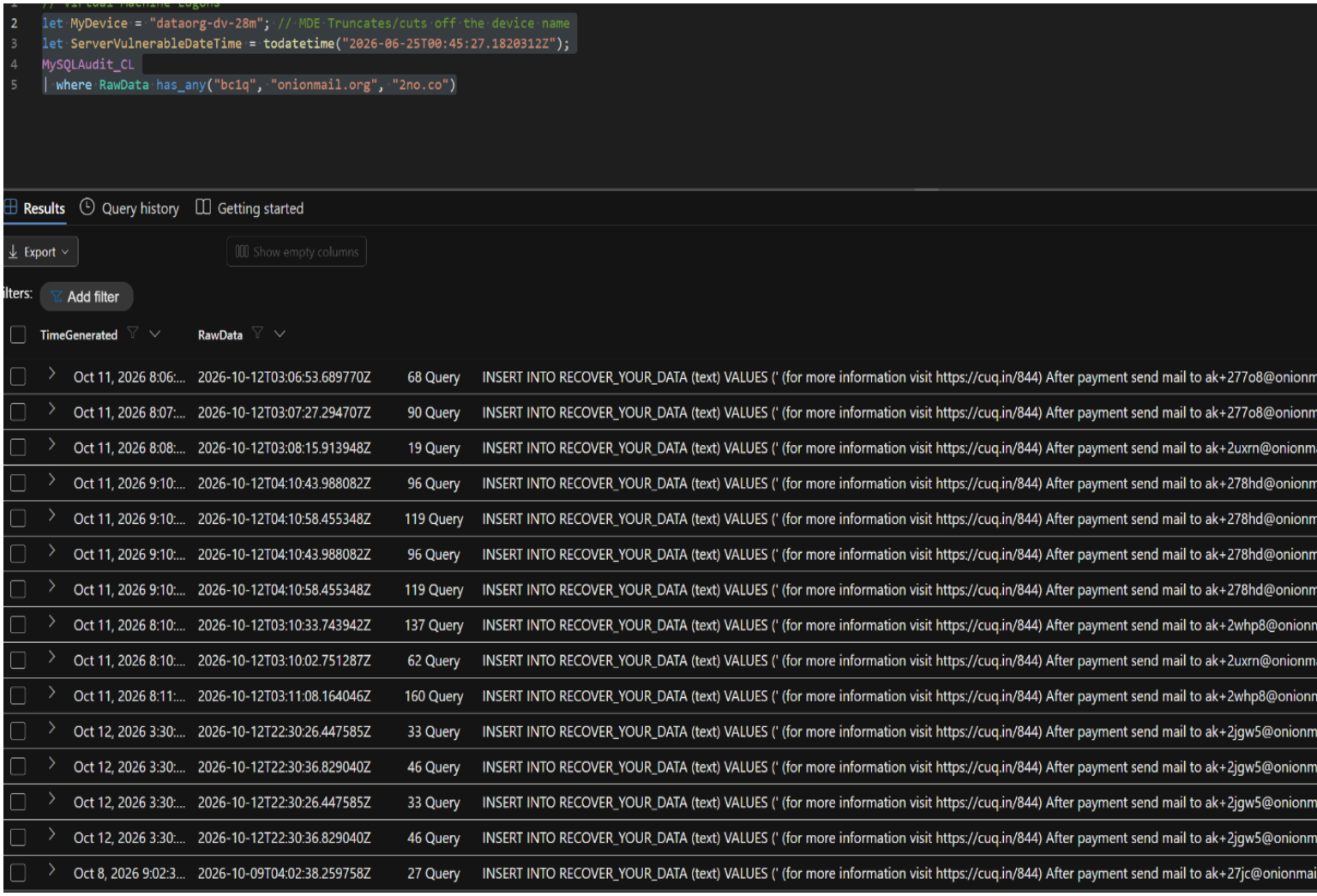
4. Indicators of Compromise (IOCs)

Category	Indicator	Context / Description
Financial / Extortion	`bc1qk9kvwhzt60u3eqcjllqlj44h0tj7w7n72apz99`	Bitcoin address provided in the database ransom note.
Threat Actor Comms	`ak+28t2@onionmail.org`	Contact email provided in the ransom note.
Threat Actor Comms	`hxxps://2no[.]co/2mysql`	External reference URL provided in the ransom note.
Campaign ID	`DATAID: 28T2`	Unique victim identifier assigned by the ransomware script.
Network (DB)	`64.89.163.91`	Primary source IP for database enumeration, exfiltration, and destruction.
Network (Host)	`80.94.95.83`	Source IP responsible for sustained network brute-force against the OS.
Network (Host)	`105.159.217.168`	Source IP that achieved the first successful interactive RDP session.
Network (Host)	`80.66.83.43`	Source IP that successfully hijacked/unlocked an active desktop session.

Hunting Query: Ransomware Note Identification

Code snippet:

```
let MyDevice = "dataorg-dv-28m";
let ServerVulnerableDateTime = todatetime("2026-06-25T00:45:27.1820312Z");
MySQLAudit_CL
| where RawData has_any("bc1q", "onionmail.org", "2no.co")
```



5. Timeline of Events

All timestamps are logged in UTC.

Phase 1: Initial Misconfiguration & Persistence

- **Oct 09, 2026, 23:55:21:** The MySQL root user configuration is modified to allow remote authentication from any external IP address ('root'@'%'), creating the initial critical vulnerability. (Source: MySQLAudit_CL)

Phase 2: Database Reconnaissance, Exfiltration & Destruction

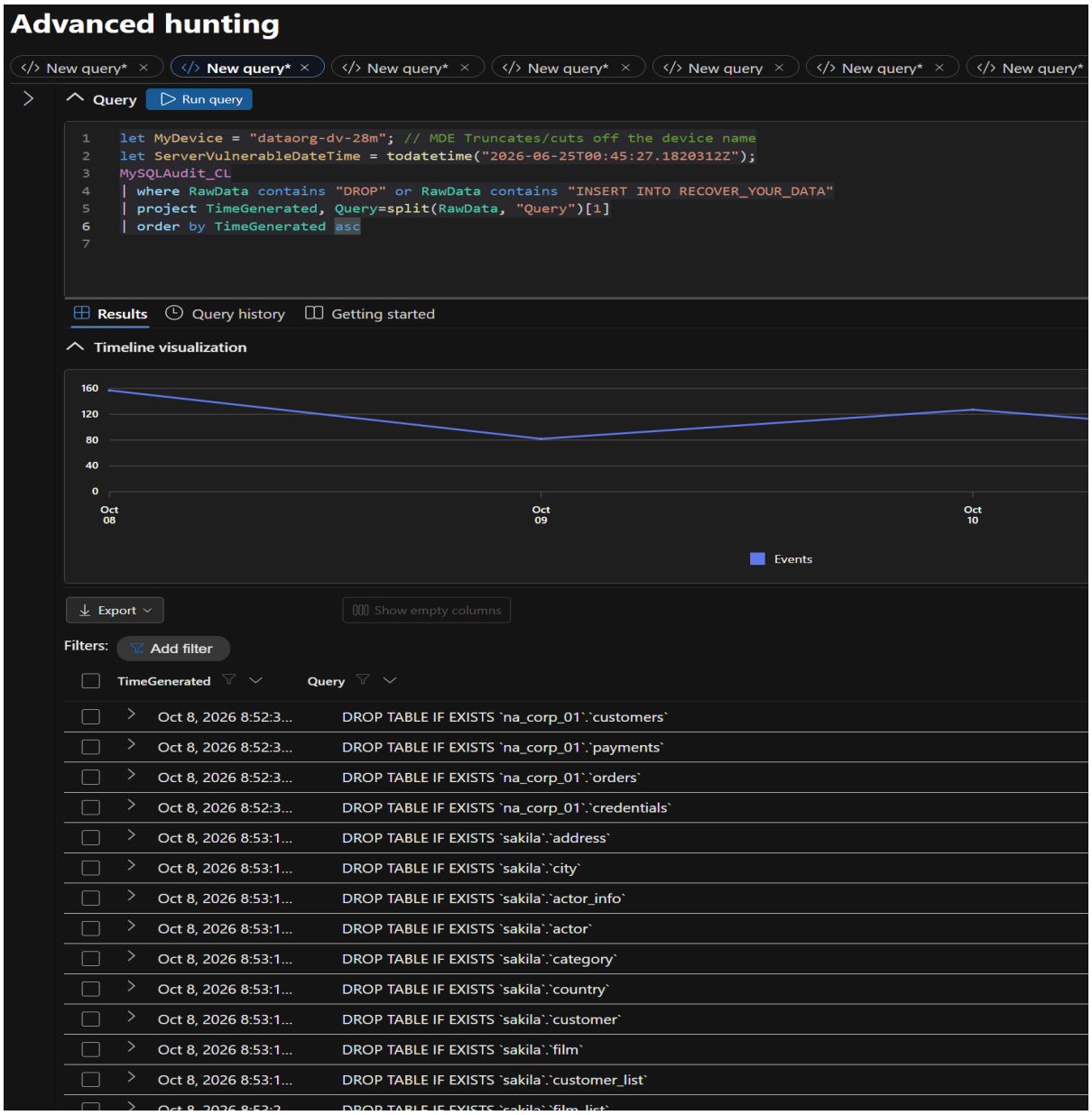
- **Oct 10, 2026, 09:55:00 - 09:55:28:** Automated enumeration script originates from IP 64.89.163.91, successfully authenticating as root. The script heavily queries information_schema to map database structures. (Source: MySQLAudit_CL)
- **Oct 10, 2026, 09:55:29: [Data Breach]** Threat actor executes a SELECT query pulling sensitive customer PII records from the dvm_corp.customers table. (Source: MySQLAudit_CL)
- **Oct 10, 2026, 09:55:37:** Threat actor executes sequential ALTER TABLE commands across all databases to drop foreign key constraints, preparing the environment for rapid deletion. (Source: MySQLAudit_CL)
- **Oct 10, 2026, 09:55:38: [Ransomware Deployed]** The script creates the RECOVER_YOUR_DATA table, inserts the ransom note demanding BTC, and immediately executes DROP TABLE against all production tables. (Source: MySQLAudit_CL)
- **Oct 10, 2026, 09:57:20 - 09:57:21:** Total destruction complete; the script executes DROP DATABASE against dvm_corp, sakila, and world. (Source: MySQLAudit_CL)

Phase 3: Host Operating System Brute-Force & Takeover

- **Oct 10, 2026, 23:15:13:** Massive OS-level brute-force attacks commence. IP 80.94.95.83 registers continuous LogonFailed attempts against the local Windows administrator account. (Source: DeviceLogonEvents)
- **Oct 13, 2026, 12:09:07: [Host Compromise]** IP 218.147.202.136 successfully authenticates to the OS via a Network logon type, bypassing initial security boundaries. (Source: DeviceLogonEvents)
- **Oct 13, 2026, 12:11:46: [Interactive Control]** IP 105.159.217.168 successfully establishes a RemoteInteractive session, granting *the threat actor full graphical control over the server via RDP. (Source: DeviceLogonEvents)*

Code snippet

```
MySQLAudit_CL
| where RawData contains "DROP" or RawData contains "INSERT INTO RECOVER_YOUR_DATA"
| project TimeGenerated, Query=split(RawData, "Query")[1]
| order by TimeGenerated asc
```



6. Root Cause / Attack Vector

The breach was facilitated by critical deviations from security architecture best practices, aligning with several MITRE ATT&CK techniques:

- **External Remote Services (T1133):** The virtual machine was deployed with administrative and database ports (3389/TCP and 3306/TCP) exposed directly to the public internet without Network Security Group (NSG) filtering.
- **Valid Accounts (T1078) & Brute Force (T1110):** The absence of account lockout thresholds and the use of default/weak credentials on both the local OS administrator account and the MySQL root account allowed automated botnets to successfully guess the credentials and gain persistent access.

- **Unknowns:** It cannot be definitively determined from the available logging scope whether the initial `'root'@'%'` remote access modification on Oct 9 was performed by an authorized internal user committing a severe misconfiguration or an earlier, unlogged threat actor exploit.

7. Response Actions

Immediate Containment:

- Isolate the `dataorg-dv-28m` virtual machine at the Azure hypervisor level (detach virtual NICs from external and internal virtual networks) to prevent lateral movement or further command-and-control (C2) beaconing.
- Revoke all active sessions and rotate all credentials for any service accounts that may have been cached or stored on the compromised host.

Eradication & Recovery:

- The host OS must be considered fundamentally untrusted. Do not attempt to clean the asset. Image the drives for forensic preservation, then destroy the compute instance.
- Rebuild the application utilizing infrastructure-as-code from a known-good, hardened baseline image.
- Restore database contents exclusively from offline, immutable backups validated prior to the October 9 vulnerability window.

8. Evidence Artifacts

- **MySQLAudit_CL:** Filtered queries mapped the precise timeline of `SELECT information_schema` (reconnaissance), `SELECT * FROM customers` (exfiltration), and `DROP DATABASE` (destruction) commands.
- **MySQLAudit_CL:** Auth logs identified the external sourcing IP addresses and the abuse of the root account.
- **DeviceLogonEvents:** Filtered for the administrator AccountName and `ActionType == "LogonSuccess"` vs `ActionType == "LogonFailed"` to definitively trace the successful RDP brute-force campaign.
- **Azure Workbooks (Geomap):** Visualized the **"Global Threat Geography: Initial Access and Breach Indicators"**. The map charts inbound attack telemetry from `DeviceLogonEvents` and `MySQLAudit_CL`, contrasting the massive volume of global brute-force noise (green bubbles) against the specific geographic origin of the successful compromise (red bubble).



9. Lessons Learned / Recommendations

1. **Implement Strict Network Security Groups (NSGs):** Immediately configure Azure NSGs to implement a "Default Deny" policy for inbound traffic. Management ports (RDP 3389, SSH 22) and database ports (MySQL 3306) must never be internet-facing. Require a corporate VPN, Azure Bastion, or strictly defined IP allow-lists for administrative access.
2. **Enforce Multi-Factor Authentication (MFA):** Require MFA for all remote administrative access to infrastructure and high-privilege application accounts to neutralize credential brute-forcing.
3. **Harden Database Configurations:** Enforce the principle of least privilege. Disable remote root logins in MySQL (bind-address = 127.0.0.1) and ensure application service accounts only have access to specific schemas, stripping global DROP or ALTER permissions from standard operational accounts.
4. **Enable Account Lockout Policies:** Configure Windows Local Security Policy or Active Directory Group Policy to automatically lock accounts after 5 consecutive failed login attempts to disrupt automated brute-force scripts.
5. **Deploy Database Activity Monitoring (DAM):** Implement SIEM alerting thresholds for anomalous database behavior, triggering critical alerts upon bulk data extraction queries or the execution of sequential DROP commands against production tables.